

Local Production

Engineering Specification

Version 8 Final | 24 September 2026

Security review, high level design, low level design and release requirements for a worldwide travel application, beginning with India, the United Kingdom, the United States, Australia and Canada.

Final implementation baseline for product, engineering, security, data and operations. Includes normative API contracts, recovery state transitions and an evidence-based production release record.

Contents

1 Readiness and product scope	2
2 Security and architecture findings	3
3 Worldwide coverage and country rollout	5
4 Quality targets and capacity model	6
5 High level system design	7
6 Module and service responsibilities	10
7 Authentication and session design	10
8 Authorization and trust boundaries	12
9 Data model and storage invariants	13
10 Discovery and client experience LLD	15
11 API contracts	16
12 Concurrent writes and offline synchronization	18
13 Secure offline packs	20
14 Ingestion routing and provider data	21
15 Performance limits and failure behavior	22
16 Emergency integrity and privacy	23
17 Operations security and recovery	25
18 Verification and release gates	26
19 Delivery plan and cost controls	28
20 Decision register and definition of done	29
21 References and verification record	29
22 Normative API field contracts	30
23 State transitions and recovery contracts	34
24 Final release record and requirement traceability	37

1 Readiness and product scope

Local helps travelers discover nearby essentials, understand local information, save places and access emergency guidance. It uses structured data and deterministic ranking; AI is not required. Retain React Native, a Spring Boot modular monolith and PostgreSQL with PostGIS. Add explicit trust boundaries, regional deployments, secure identity, verified data publication, offline synchronization and operational acceptance criteria.

Document status: final engineering baseline, superseding v7. This document defines the production architecture, security controls, field contracts, failure behavior and release evidence the engineering team must implement. It authorizes no deployment by itself. Production launch requires the separate release record in Section 24; an implementation must demonstrate the specified security, correctness and reliability targets. The v6 findings are design findings, not penetration-test results or a claim that every possible vulnerability has been discovered.

Market direction: worldwide expansion, with India, the United Kingdom, the United States, Australia and Canada as the first country group. Country selection does not establish nationwide coverage. Publish an explicit supported-city catalogue and enable each capability only where its data, language, operating cost and safety checks pass. Cities and exact demand remain launch decisions. Traffic figures are planning assumptions. Technical limits and retention values are baseline defaults, subject to the stated jurisdictional overrides, validation gates and controlled change process.

1.1 First release behavior

- Nearby list and map for hospitals, pharmacies, police, ATMs, restaurants, cafes, hotels, transit stops, supermarkets and fuel stations. Transit stop discovery does not imply transit routing.
- Category and text search; details with name, category, location, straight-line distance and source-qualified opening hours. Missing hours display as unknown.
- Online walking and driving route previews, only in tested routing areas. Voice-guided turn-by-turn navigation and offline route computation are separate scope decisions.
- Reviewed country and emergency information, plus curated emergency-capable facilities in each launch area. Emergency access works without an account.
- Weather, indicative currency conversion, a flat saved-place list and optional accounts for cross-device synchronization.
- Downloadable city packs containing licensed map data, POIs and reviewed local content. Local discovery and saved places work without connectivity. Previously downloaded routes can be viewed with an age label; new routes require connectivity.
- An accessible correction report flow and a staffed review queue. Emergency content requires two-person publication approval from the first release.

Defer ratings, photos, price filters, enrichment, transit/cycling routing, itinerary scheduling, translation, travel history, visitor ranking variants and radial views. Reassess provider terms before adding enrichment. Remove v6's trip-creation download trigger because trip creation is deferred; use city selection, a download action and a contextual Wi-Fi suggestion instead.

1.2 How engineers use this specification

Sections 2 and 3 identify the original findings and coverage policy. Sections 4 through 6 define capacity and HLD; Sections 7 through 15 define security and LLD. Sections 16 through 20 define privacy, operations, verification and delivery. Section 21 records sources. Sections 22 and 23 supply normative wire, state-transition and recovery contracts. Section 24 records settled decisions, requirement traceability and launch authorization. MUST indicates a release requirement. Normative field/transition definitions govern implementation details; change a conflicting earlier description through the controlled document process instead of choosing behavior silently.

2 Security and architecture findings

Severity expresses potential impact if the missing control is not implemented. Critical findings concern safety information integrity; High findings can expose accounts, precise locations or service availability. Controls for these findings are specified in this final baseline; implementation closure remains dependent on evidence. They are not verified exploitable bugs. Source references refer to sections in local-project-document-v6.md.

ID and priority	Evidence in v6	Required resolution and release evidence
F01 Critical	Sections 3, 4, 12: verification at launch, ongoing workflow deferred	Enforce independent review, provenance, expiry and emergency withdrawal at MVP. Demonstrate draft-to-publish restrictions and rollback.
F02 High	Section 5: JWT with refresh tokens only	Specify native OIDC flow, secure storage, rotation, reuse handling, logout and recovery. Test token theft and multi-device revocation.
F03 High	Sections 3, 8, 10: accounts and saves without ownership policy	Derive account identity from validated token; enforce ownership in service and database access. Negative tests for every private endpoint.
F04 High	Sections 8, 10, 13: GPS and analytics without retention or logging rules	Foreground-only location by default; redact coordinates and emergency events; implement deletion and transfer controls. Inspect real telemetry exports.
F05 High	Sections 3, 5, 10: SQLite/offline mirror undefined	Separate public packs from private data; sign manifests, verify hashes, bound extraction and use atomic activation. Test malicious and interrupted downloads.
F06 High	Sections 8, 9: admin content without privilege controls	Separate admin identity, phishing-resistant MFA, country-scoped roles and immutable publication audit. Test self-approval denial.
F07 High	Sections 5, 8: cache and rate control without limits	Bound request size, radius, route complexity, downloads and reports; add admission control and independent pools. Load test abuse and cache failure.
F08 High	Sections 5, 9: external OSM/provider content	Treat tags, names and reports as untrusted. Parameterize queries, escape admin output and restrict outbound connections. Test injection, SSRF and oversized data.
F09 High	Sections 5, 8: hosting unspecified	Private data services, least-privilege workload identities, KMS-backed secrets and isolated environments. Verify infrastructure policies and external exposure.

ID and priority	Evidence in v6	Required resolution and release evidence
F10 High	Section 12: restart and rollback mentioned, no recovery objectives	Implement replicated deployment, encrypted backups, restore drills, writer fencing and tested runbooks. Meet measured RTO/RPO.
F11 High	Sections 5, 10: walking/driving route assumptions	Build and serve mode-specific graphs; validate real walking/driving behavior and unsupported boundaries. Do not imply live traffic or safe access.
F12 High	Sections 3, 10: offline scope versus live OSRM	Declare offline features and unavailable functions explicitly. Airplane-mode tests must prove emergency and discovery availability.
F13 High	Sections 5, 9: no map tile source or offline map license	Use self-hosted or explicitly licensed tiles/packs. Public OSM tile servers cannot be bulk-downloaded for offline use. Retain attribution and license evidence. [S5-S7]
F14 High	Sections 5, 8: Overpass deployment and discovery path unclear	Serve imported PostGIS datasets; isolate ingestion and graph builds. Remove live Overpass from mobile request paths.
F15 High	Sections 3, 5: concurrent saves unspecified	Conditional versions, durable idempotency and account-local ordered change feed. Test duplicate, reordered and conflicting operations.
F16 High	Sections 11, 12: no secure delivery gate	Dependency, secret and container scans, artifact provenance, signing and independent security review before release.
F17 Medium	Sections 6, 11: MAU treated as load estimate	Use request rate, concurrency, dataset size and CDN egress. Demonstrate stated performance under bursts and node failures.
F18 Medium	Sections 5, 9: generic cache policy	Define key dimensions, TTL, freshness and license ceilings; prevent cross-user caching and cache stampedes.
F19 High	Sections 5, 9, 12: no regional ownership model	Pin personal writes to account home region; keep public data separately replicated. Test region loss without split brain or silent data relocation.
F20 Medium	Sections 3, 7: one country timezone and sparse validation	Model multiple time zones, scripts and local formats. Validate per city, category and route mode with explicit thresholds.
F21 Medium	Sections 6, 15: inexpensive and production-grade claims	Replace cost assurances with measured regional budgets; include HA, tiles, egress, backups, support and identity costs.
F22 High	Sections 11, 12: quality checks lack ownership and pass criteria	Assign accountable owners, measurable SLOs, security acceptance tests and stop-ship rules.

Resolve F01-F16, F19 and F22 before exposing the affected capability publicly. Medium findings still require closure or documented acceptance with an owner, compensating control and expiry. Severity acceptance cannot waive an unresolved critical safety defect.

3 Worldwide coverage and country rollout

Separate three coverage levels: country information, city discovery/offline packs, and routing areas. A country record MUST NOT enable all cities or all route modes automatically. Coverage responses include dataset versions, supported polygons, languages, verification times, capability flags and explicit unsupported reasons.

Initial market	Reference account region	Data and localization validation
India	Mumbai	Regional scripts, address quality, varied emergency coverage, local access restrictions and country-specific privacy review.
United Kingdom	London	Country/territory boundaries, walking access, multiple emergency services and UK transfer assessment.
United States	Northern Virginia	State-specific privacy applicability, large route areas, varied emergency dispatch/facility data and multiple time zones.
Australia	Sydney	Remote-area coverage, state/territory differences, multiple time zones and emergency access outside cities.
Canada	Montreal	Provincial rules and language needs, English/French content validation, sparse rural coverage and multiple time zones.

These are AWS reference deployment locations, not a conclusion that each law requires local hosting. Confirm service availability, contracts, identity-provider location and approved transfer routes before provisioning. Other countries remain unsupported for verified Local guidance until their launch gates pass; the app can still show downloaded material and allow manual selection of a supported destination.

3.1 City certification

The data lead chooses city polygons and buffered routing extracts. Sample at least 20 known places per MVP category per city, stratified across neighborhoods; this is the baseline pilot threshold, not statistical proof of completeness. Require at least 95% correct identity/category/location in the sample and report observed coverage and uncertainty separately. Missing hours do not fail a place; invented open status does.

For emergency-listed facilities, independently verify every published record in the curated launch list, including service type, access address and source date. Do not present a general hospital as guaranteed emergency care. Compare at least 50 walking and 50 driving test routes per routing area against documented local access constraints, including bridges, restricted roads, pedestrian areas, mode differences and border cases. Any known dangerous route blocks the affected mode/area until corrected. Large or diverse cities require more samples based on observed failure patterns.

Publish a city only when content, routing, offline installation, licensing, accessibility and load gates pass together. Roll out one certified city per initial country first, then increase coverage independently. The actual five cities remain a product/data selection gate.

3.2 International data rules

Use ISO country codes, BCP 47 locale tags, Unicode throughout and IANA time-zone identifiers resolved by coordinates. Countries may have several languages and time zones. Store timestamps in UTC; compute hours using the place's zone, holidays and daylight-saving transitions. Use ISO currency codes and decimal arithmetic; include rate source, base currency and as-of time. English is the fallback only where approved; translated emergency wording requires review, not automatic substitution. Distances and route units follow user preference. Account home region is selected through account onboarding policy and stays stable when the traveler moves.

4 Quality targets and capacity model

These are acceptance targets, not measured performance or service guarantees. Count valid requests at the public edge; exclude client-invalid requests and abusive traffic, but include overload rejection of valid traffic and dependency failures. Keep separate SLOs for discovery, route computation, private synchronization and offline operations. Use a rolling 30-day window for availability and user experience.

Capability	Required acceptance target	Measurement
Discovery and saved places APIs	99.9% successful valid requests	End-to-end regional synthetic probes and edge outcomes; 0.1% error budget.
Discovery and private reads	p95 <= 400 ms; p99 <= 1 s	Client-region probe to service response; warm and cold cache reported separately.
Supported online routing	99.5%; p95 <= 1.5 s; p99 <= 3 s	End-to-end, within supported graph and request bounds.
Nearby screen	p95 <= 2 s on agreed mid-range devices	Reference 4G conditions; location fix delay shown separately.
Emergency screen	p95 <= 1 s from local verified data	First-install, offline and expired-session device tests.
Mobile stability	>= 99.8% crash-free sessions	Privacy-filtered release cohort; ANR/hang rate tracked separately.
Ordinary POI ingestion	target <= 24 h source-to-publish	Expose actual source timestamp and lag; stale data is visible.
Approved emergency correction	<= 15 min to online manifest	Measured after approval; offline devices update only after reconnecting.

Report private-service latency at home-region ingress separately from end-to-end traveler latency. Benchmark each launch geography against each account home region; the 400 ms target is not a universal cross-continent mobile latency guarantee. Measure public discovery from each relevant client geography.

4.1 Traffic assumptions

Use concurrent actively interacting sessions, not registered users or MAU. Baseline dynamic request rate = active sessions x requests per second per active session. Proposed planning mix: discovery 60%, details/content/utilities 20%, routes 10%, private synchronization/reports 10%. CDN tile and pack traffic is additional. Vary this mix in stress tests; route-heavy traffic can be the limiting case.

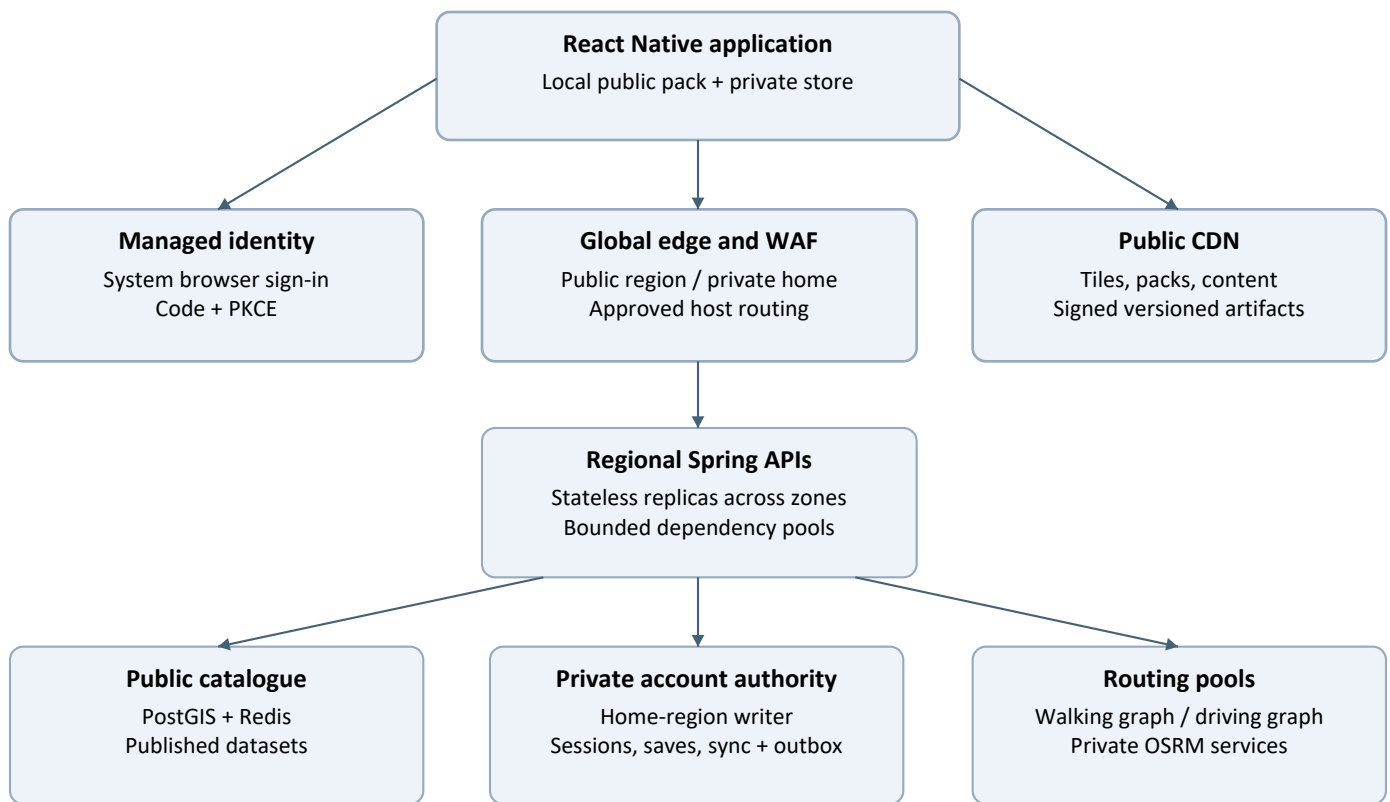
Stage	Active sessions and assumed rate	Design load	Launch interpretation
Five-city beta	1,000 x 0.2 req/s	200 sustained RPS; 600 burst	Aggregate across regions; test normal concentration and the 80% regional-skew case in G7.
Initial growth	5,000 x 0.3 req/s	1,500 sustained RPS; 3,000 burst	Enable after measured region capacity and funding review.
Global event target	10,000 x 0.5 req/s	5,000 sustained RPS; 10,000 burst	Engineering scale target; no claim existing hardware supports it.

At 5,000 RPS and an assumed measured mean latency of 0.2 seconds, Little's Law gives about 1,000 in-flight requests. A p95 latency cannot substitute for the mean in this calculation. At a 10% route mix the route fleet must serve 500 RPS; benchmark walking and driving separately. If 2,000 daily downloads average 200 MB each, delivery is about 400 GB/day before retries, roughly 12 TB per 30-day month. The 200 MB figure is only a sizing example; compute real pack sizes before making user-facing promises.

Size API replicas from measured safe per-replica throughput: required replicas = ceiling(regional peak RPS / tested safe RPS per replica), then add availability-zone failure headroom. Do not use CPU alone; scale on latency, concurrent work and queue time. Verify that the surviving zones can carry peak traffic after a zone fails. Public dataset memory, geospatial query cost, DB connections, OSRM graph memory and network egress are independent capacity limits.

5 High level system design

Local uses regional stateless API replicas with a modular codebase, independent routing and data-processing workloads, managed regional state and a global CDN for public artifacts. A modular monolith does not mean one server. Avoid introducing separate network services for every feature before measured load or ownership requires it.



Isolated ingestion, review and build workers publish public datasets and CDN artifacts.

Private APIs run in the account home region; public-region APIs do not access remote user databases.

Trust boundaries: device / edge / private services / external data / privileged publication.

Figure 1 Regional serving and account ownership

The app calls the selected public region for nearby requests and the stable account home region for private requests. The diagram's private database arrow is a logical dependency: a public-region API **MUST NOT** directly connect to a remote personal database. Private APIs execute in the home region. The client resolves approved regional hosts using signed configuration, sends account tokens only to the private API, and sends no account token with public discovery requests. Do not put exact coordinates or tokens in URLs.

5.1 Reference deployment

Use AWS as the reference implementation: Route 53, CloudFront, WAF, Application Load Balancer, ECS/Fargate for Spring APIs and workers, RDS PostgreSQL/PostGIS, managed Redis-compatible cache, SQS, S3, KMS, Secrets Manager and regional monitoring. Deploy graph-heavy OSRM and tile build workloads on separately sized compute with controlled lifecycle and private networking. Confirm exact supported versions and service features during implementation; pin a tested bill of materials and supported Java/Spring/React Native versions.

Each launched account region has at least two API replicas across two availability zones, a managed primary/standby private database, independently budgeted public catalogue capacity and private service endpoints. Regional cache failover and object storage policies are infrastructure-as-code. For a low-traffic beta, public and private schemas can share one managed PostgreSQL cluster using distinct roles and pools; split them before public ingest/query load compromises private SLOs. Five regions incur five sets of fixed reliability costs. A cheaper beta may reduce public coverage or delay a region, but must not silently remove redundancy or relocate personal data.

Only the edge, approved public object paths and identity endpoints are Internet-facing. Database, cache, queue consumers, OSRM, management endpoints and ingestion workers are private. Use workload IAM roles instead of static cloud access keys. Restrict egress by dependency; data import workers do not have personal-data permissions. Admin access uses a separate hostname, identity client and API audience, with a web backend session protected from CSRF.

Require TLS 1.2 or later with hostname and certificate validation for mobile, CDN, identity and provider traffic. Encrypt remote API-to-database, cache, queue and service connections; private networking does not replace transport encryption. Where OSRM or another component lacks native TLS, terminate authenticated TLS at a controlled proxy and permit plaintext only over local loopback or an explicitly isolated same-host connection. Never disable certificate validation in production.

5.2 Regional failure and data ownership

Public catalogues, tiles and reviewed content are immutable versioned datasets that may be replicated to approved serving regions. Account data has one writable home region and one authoritative primary. Never use GPS to move account ownership. Account-region migration is disabled in the first release. A future move requires an audited workflow, applicable transfer assessment, encryption, reconciliation and a fenced cutover.

Maintain a strongly consistent, privacy-minimal identity-routing directory mapping (issuer, subject) to one account ID, home region and routing epoch. Reserve the mapping atomically before creating regional account state; retries complete the same reservation. Region-local uniqueness alone cannot prevent duplicate accounts in two regions. The reference directory is a separate multi-AZ control database in London; its identity metadata is personal data and requires an approved transfer/processor assessment for every launch market. Do not replicate the entire directory to all serving regions. Bootstrap returns an authenticated routing result referencing signed-allowlisted hosts; it grants no resource authorization. Cached verified routes can reach an existing home account during directory failure, but new registration and region migration fail closed. Implement reservation recovery, lifecycle and fencing as specified in Sections 22 and 23; the generated OpenAPI and ADR package must preserve these contracts.

During a region outage, allow public reads from approved healthy regions and local packs. Queue personal changes on-device with a clear pending status. Do not accept independent writes to two regions. Region promotion requires confirmed fencing of the old writer, recovery to a known log position, explicit RPO assessment and client route update. If no approved secondary exists, restore in the original region when available; prolonged personal sync unavailability is safer than silent split brain.

6 Module and service responsibilities

Module or workload	Responsibility and data ownership	Scaling and isolation
Identity adapter and policy	Validate tokens; map subjects; manage account status and authorization	Part of API; separate admin policy; small bounded identity dependency pool.
Discovery	Nearby/category/text queries; deterministic ranking; source freshness	API replicas plus PostGIS public catalogue; no live import calls.
Content and emergency	Versioned country/city content; verified emergency publications	Public read path and CDN; separate protected editorial API.
Personal	Saved places, session controls, sync feed and deletion	Home-region single writer; owner-scoped repository layer.
Routing gateway	Coverage/profile validation; deadlines; graph selection	Separate walking/driving OSRM pools with bounded concurrent requests.
Utilities	Cached weather and FX adapters; provider budget	Independent pools and scheduled refresh; never block discovery.
Offline publication	Pack manifests, compatibility and distribution	Object storage/CDN; build workers run away from serving fleet.
Feedback	Validated reports and review status	Durable queue; moderation worker; cannot publish directly.
Ingestion and graph build	Validate OSM extracts, normalize, test, publish dataset versions	Isolated CPU/memory/disk budgets; no user traffic credentials.
Operations	Metrics, audit export, alerting, backup and deployment	Regional infrastructure; access limited by function.

Within Spring, use packages/modules with public interfaces and private repositories. Architecture tests prevent cross-module table access. Transactions stay inside an owning module unless an explicitly documented same-database transaction requires otherwise. External effects use an outbox and durable queue. No network call or graph computation occurs while holding a personal-data write lock.

Start with managed queues, not Kafka or distributed transactions. Extract a service only when independent scaling, isolation or team ownership justifies it and its contract/observability are ready. Likely first extractions are routing, pack building and ingestion; these are already separately deployed.

7 Authentication and session design

Use a managed OpenID Connect provider with native-app Authorization Code plus S256 PKCE. Use the OS system browser, registered app/universal links, exact redirect URI matching, state and nonce validation. No client secret belongs in the mobile binary. Do not use embedded login WebViews, implicit flow or password grant. The app backend is an OAuth resource server, not a custom password server. [S1-S3]

Provider procurement remains a blocking decision because residency, passkeys, refresh replay detection, device-session revocation and pricing must be proven. Select a provider only after the following integration tests

pass; do not silently replace missing capabilities with homegrown token cryptography. Passkeys are the preferred sign-in option where supported. If passwords are enabled, the provider handles password policy, secure hashing, breached-password screening and recovery protections.

7.1 Token and recovery contract

Set access-token lifetime to five minutes and refresh sessions to a seven-day inactivity / 30-day absolute limit. Require refresh-token rotation with reuse detection or an equivalently reviewed sender-constrained scheme; use rotation for the initial integration. Serialize refresh requests on each device and atomically save the replacement token. A stolen/reused refresh family is revoked; recovery requires sign-in. If a rotation response is lost or a process exits before secure storage commits, use only the provider's documented recovery mechanism; otherwise require interactive sign-in. After verifying the same issuer/subject, ordinary reauthentication can resume that account's protected pending saves. It cannot attach pending state to a different account. Explicit logout still destroys the local account data as specified. Any provider grace interval must be bounded, documented and tested for request races.

Store refresh tokens in iOS Keychain / Android Keystore-backed storage, with backup/export restrictions; keep access tokens in memory where feasible. Never store tokens in AsyncStorage, logs, crash reports, URLs or the public SQLite database. Remove local credentials on logout and account switch. A compromised unlocked device can still expose data; hardware-backed storage reduces exposure but is not a guarantee.

Validate signature, an explicit algorithm allowlist, issuer, audience, expiry, not-before and required scopes. Use access tokens, never ID tokens, for API authorization. Accept only configured issuer/key URLs; token-supplied URLs must not trigger remote fetches. Cache trusted JWKS with bounded refresh and overlap during key rotation; an unknown key triggers at most one rate-limited refresh, then rejection. Bound clock skew to 60 seconds. Configure Spring audience validation explicitly. [S4]

7.2 Revocation and account state

Use a provider-supported signed session identifier or supported introspection mapping to bind each protected request to a server-side session record. Never trust a client-chosen session ID. If the shortlisted provider cannot support secure per-session binding, it fails procurement. At first verified login, reserve the global identity-directory mapping and create the home-region account using unique (issuer, subject); link identities only after proof of both accounts, never by matching email alone.

/v1/accounts/resolve and /v1/me/sessions/bootstrap accept validated provider credentials before a Local session exists. Resolve only reserves/returns the caller's minimal routing record; it grants no private-resource access. Both enforce approved issuer, audience, client, subject and provider-evidence requirements. All other private APIs require a bound active Local session, except the narrowly scoped deletion receipt status and receipt recovery endpoints in Section 22.5. For session bootstrap, validate the access token and trusted provider session/authentication evidence, then lock the account row in a transaction, recheck account state and security cutoff, and create the session at the current auth_epoch. Logout-all, recovery and deletion lock the same account row, increment auth_epoch, advance security_cutoff and revoke affected sessions atomically. Bootstrap rejects provider authentication at or before the cutoff; a refreshed token issuance time is insufficient. A revoked provider-session binding cannot be revived. Concurrent bootstrap and revocation serialize: a session created first is revoked, while a later bootstrap must prove fresh authentication. Reconcile provider timestamp precision and clock skew explicitly; never round a stale authentication into an accepted one.

For every private request check active account and session status in the home-region authority. Cache ordinary read checks for at most 30 seconds; private mutations, account export/deletion, session revocation and admin actions read authoritative state without that cache. The ordinary-read revocation window is at most 30 seconds after the Local revocation transaction commits. Provider detection and event delivery delay are separate measured

quantities, not included in that bound. When authoritative status is unavailable, fail closed for private APIs and preserve local offline use. Do not claim that JWT signature verification alone enforces immediate logout.

Receive provider recovery, credential-change, account-disable and refresh-reuse events through an authenticated integration. Verify source, intended recipient, signature/channel, event ID and replay constraints; deduplicate durably. Events may only restrict state or advance a cutoff, never reinstate a revoked session. Reconcile missed events through the provider's supported interface. Local event handling must commit an accepted revocation within 30 seconds under declared peak load; procurement must establish and test the separate provider-delivery/reconciliation budget. Alert on delay or reconciliation failure. G1 includes forged, duplicate, reordered, delayed and lost events.

Logout-this-device revokes only its bound Local and provider refresh sessions; other devices remain active. Logout-all/recovery performs the atomic transition above and requests provider-wide revocation through a durable retry workflow. Keep revocation records until affected credentials can no longer be accepted. Ordinary private-read checks retain the 30-second cache window; mutations and sensitive actions enforce live authority. Offline logout clears local access immediately but cannot claim remote revocation until acknowledged by the server. On logout/account switch, cancel account-specific requests and synchronization, wipe credentials, destroy the private-store encryption key, and remove its database, cached exports and pending queue. Warn before logout if unsynchronized changes will be discarded. Public packs remain available. Late callbacks from the old account cannot recreate its private store or run under the next account.

Export workers check current account/session authorization before generating and releasing private data; the download endpoint checks live authorization. Revocation or deletion cancels pending exports and invalidates download grants.

Require recent authentication within five minutes for deleting/exporting an account or changing security settings. Use generic login/recovery responses to limit enumeration, rate-limit per account/network with careful shared-network behavior, notify the owner of recovery and support a secure lost-device path. Recovery and MFA reset are security-sensitive workflows with audit trails. Admins require separate privileged accounts and phishing-resistant MFA; consumer accounts never receive admin power from a client flag.

8 Authorization and trust boundaries

Default deny. Authentication identifies a caller; authorization decides whether that caller can act on this object in this state. Resource IDs are opaque but never substitute for access control. Public discovery and emergency functions work as guests; account functionality is optional.

Protect credentials and sessions, private saved-place collections, transient precise location, emergency-content integrity, signing keys and service availability. Model unauthenticated bots, a malicious signed-in user, a lost or compromised phone, hostile source data, a compromised staff account and a compromised build/publishing dependency. Review how each can cross the boundaries below, then map the relevant F01-F22 controls and G1-G12 tests to those attack paths. A trusted content source can still be mistaken; authenticity and factual accuracy need separate verification.

Actor	Permitted actions	Explicit restrictions
Guest	Read published coverage, nearby places, routes, utilities and public packs	No private saves, private exports or editorial data; bounded abuse limits.
Consumer	Guest actions plus own saves, sessions, sync, report history and deletion	Owner is resolved from verified identity, never a body/query user ID.

Actor	Permitted actions	Explicit restrictions
Content editor	Draft corrections for assigned countries	Cannot approve own draft or publish emergency changes.
Reviewer	Review assigned countries and approve a different author's draft	No consumer private-data access; self-approval rejected.
Publisher service	Publish an approved immutable version and audit event	No human interactive login; cannot create an approval.
Support	Minimal account metadata needed for a documented case	No saved places or location history by default; time-bound audited access only.
Operator	Deploy/restore infrastructure under scoped roles	No standing content publication or bulk user-data access.

For each private read/write, repository queries include the authenticated owner. Return a consistent 404 for missing or not-owned private resources. Define object and field allowlists in DTOs; do not bind database entities directly from JSON. Ignore/reject caller-supplied owner, role, approval state or region changes. Method-level and endpoint policy tests cover every route, including batch APIs and export jobs. Service identities use distinct scopes and cannot impersonate a consumer without an explicitly audited delegation contract.

Trust boundaries are device-to-edge, public-to-private data plane, API-to-state services, third-party data-to-importer, editor-to-publisher and CI-to-production. Treat OSM tags, provider JSON, reports, filenames and downloaded packs as untrusted inputs. Use parameterized SQL, output encoding, sanitized text and allowlisted external link schemes. Disable arbitrary URL fetches and block private/link-local/metadata addresses, including after redirects and DNS resolution, in any approved fetcher.

Browser admin sessions require Secure/HttpOnly/SameSite cookies, restrictive CORS/CSP and short idle timeouts. State-changing requests require an unpredictable session-bound CSRF token and a documented fail-closed same-origin Origin/Referer policy. GET/HEAD never mutate state. SameSite, CORS and CSP supplement these checks. OAuth callbacks use expiring, one-time state and nonce. Native bearer APIs reject cookie-only authentication. G1/G3 include cross-site forms/fetches, invalid CSRF tokens and callback replay. Protect management/health details from public enumeration; expose only minimal readiness status at the load balancer. Audit privileged decisions without retaining content payloads or secrets.

9 Data model and storage invariants

Use server-generated UUIDs for application objects, timezone-aware timestamps, decimal numeric FX fields and explicit schema migrations. Source OSM identity is (source, osm_type, osm_id), not a numeric ID alone. Keep source identity and stable application place identity separate so merges/deletions do not break saved places. Version public records and never erase provenance when applying curated overrides.

Entity	Required fields and indexes	Invariant
account	id, issuer, subject, home_region, state, auth_epoch, security_cutoff, created_at; unique issuer/subject	Bootstrap, revocation, deletion and private writes serialize through this row; directory enforces global identity ownership.

Entity	Required fields and indexes	Invariant
session	id, account_id, issuer-scoped trusted_provider_session, auth_time, epoch_at_establishment, revoked_at, expires_at	Unique trusted binding; cannot be supplied or revived by the client.
place_identity	place_id primary key; source, osm_type, osm_id unique	Stable across releases; saved places reference this identity.
place_version	composite key dataset_version/place_id; category, names, geography point, country, timezone, hours_raw, deleted_at	Immutable published snapshot; GiST location index plus release/category filters; unknown hours stay unknown.
place_alias	previous_id, canonical_id, source_reason, version	Saved references resolve to canonical ID; merges are audited.
saved_place	account_id, place_id, version, deleted_at, updated_at	Unique owner/place pair; deletes retain a bounded tombstone.
account_sync_state	account_id, next_sequence, generation	Serialize changes per account; cursor cannot skip uncommitted changes.
account_change	account_id, sequence, kind, object_id, version, payload	Unique account/sequence; excludes unrelated users.
content_version	composite key record_id/version; country, locale, payload/hash, approved_hash/by/at, source URLs, verified_at, review_due, status	Approval binds immutable hash; two distinct editorial actors for emergency publication.
coverage_release	composite key area_id/release_version; polygon, capabilities, dataset_version, graph_versions, published_at	Separate active-release pointer; each enabled capability has passing evidence.
pack_manifest	pack_id, area_id, version, schema_version, hashes, lengths, issued_at, expires_at, content_versions, key_id, signature	Immutable signed metadata; monotonic accepted-version floor; no private data.
idempotency	owner, storeEpoch, method, canonical_path, key, request_hash, result, expires_at	Unique scope; different payload with same key is rejected; old lineage cannot replay into a restored writer.
outbox and inbox	event_id, aggregate_version, schema_version, state, timestamps	Mutation/outbox atomic; each consumer deduplicates event ID.
feedback and audit	actor reference, target, action, timestamps, reason/status	Reports cannot publish; audit append-only and access restricted.

Private saved place IDs are logical references to durable public identities, not cross-region foreign keys into a public release. Maintain a minimal versioned identity/alias/tombstone projection in each account region for supported destinations. Catalogue deletion/rebuild cannot cascade-delete saves. Distinguish an unknown ID from projection lag; lag returns a retryable DATASET_UNAVAILABLE response rather than invalidating existing saved state. Aliases cannot form cycles; a public merge must not silently change a private object's identity, ETag or deletion intent. Any private consolidation is an explicit versioned migration.

Use separate database roles for API reads/writes, migrations and ingestion. Row-level security can provide defense in depth for private tables only if connection-scoped identity is set transactionally and reset safely; it does not replace repository authorization tests. Protect production backups with separate keys/roles and test restoration.

9.1 Representative schema and query contract

The following SQL is an implementation pattern, not a complete migration. Add partitioning only after measured table size and query plans justify it. Start by splitting large public catalogues by coverage region/dataset, not by arbitrary user coordinates.

```
CREATE UNIQUE INDEX account_identity
  ON account (issuer, subject);
CREATE UNIQUE INDEX saved_owner_place
  ON saved_place (account_id, place_id);
CREATE INDEX place_location_gist
  ON place_version USING gist (location);
CREATE INDEX place_category_release
  ON place_version (category, dataset_version);

-- location is geography(Point, 4326); bind every parameter.
WITH origin AS (
  SELECT ST_SetSRID(ST_MakePoint(:lon, :lat), 4326)
         ::geography AS g
)
SELECT p.place_id AS id, p.names,
       ST_Distance(p.location, o.g) AS meters
FROM place_version p CROSS JOIN origin o
WHERE p.dataset_version = :dataset
      AND p.category = :category
      AND p.deleted_at IS NULL
      AND ST_DWithin(p.location, o.g, :radius_m)
ORDER BY meters, p.place_id
LIMIT :bounded_limit;
```

ST_DWithin on geography uses metres and is index-aware. Keep the indexed column's type consistent; do not silently measure degrees as metres. Inspect EXPLAIN ANALYZE with realistic density, cities at different latitudes and cold-cache runs. [S8]

10 Discovery and client experience LLD

1. Resolve permission state. Ask for foreground approximate/precise location only when needed; allow city/manual map selection. No background tracking for MVP.
2. Display the last local dataset immediately if present, including its area and age. Resolve current location asynchronously with a deadline and accuracy indicator. Do not block the emergency shortcut on GPS.
3. Debounce user movement/search, cancel stale requests and use request sequence numbers so late responses cannot replace newer results. Refresh only after meaningful movement or user action; never send every GPS tick.
4. Validate coordinates, coverage, category, radius and limit. Select the published dataset snapshot, run a bounded spatial query, compute exact final distances and order deterministically by distance then place ID.
5. Return source/freshness metadata, an opaque cursor and partial/unsupported status. Unknown hours remain unknown. The initial ranking is distance-based; do not imply medical suitability or safety from rank.
6. Merge public results with local saved flags on the device. Personalized flags are never stored in a shared discovery cache.

For initial nearby requests require latitude [-90, 90], longitude [-180, 180], finite numeric values, radius 100-10,000 metres, at most 50 results and an approved category list. Search text is at most 200 Unicode characters after normalization. These are baseline limits; changes require an updated load and abuse test. Any expanded rural/emergency radius requires an explicit coverage policy and bounded query budget; do not silently search the planet.

Pagination uses a signed opaque cursor containing dataset version, query hash, distance/ID position and expiry. Hold published snapshots for the cursor TTL, initially 15 minutes; if unavailable return a restartable cursor-expired error. A moved origin invalidates the cursor. Do not cache the first 50 results of a cell-centre search as if they were complete for every point in that cell. Candidate caching must use a proven superset for the cell plus radius; recompute exact filtering/ranking per request or bypass caching.

Client modules: LocationController, CoverageRepository, DiscoveryRepository, RouteRepository, PublicPackStore, PrivateStore, AuthSessionManager and SyncEngine. Repository interfaces choose network or local data and expose loading, fresh, stale, empty, unsupported, denied and error states. Use a local spatial index/R-tree for POIs and normalize offline/online category behavior. Keep expensive decoding, database and map work off the UI thread. Bound image/memory caches and virtualize lists. Accessibility covers large text, screen readers, contrast and keyboard/switch navigation where applicable.

11 API contracts

Translate Sections 11, 22 and 23 into OpenAPI and executable contract tests before feature implementation. JSON uses stable field names, explicit nullable fields and UTC ISO timestamps. Additive changes remain backward compatible; breaking changes need a versioned route and a mobile deprecation plan. Coordinates belong in request bodies to reduce URL leakage; all infrastructure logging must still redact bodies. Public responses containing location-derived results use Cache-Control: no-store at shared HTTP caches; internal candidate caching is separately controlled.

Method and path	Caller and behavior	Key limits/status
GET /v1/coverage	Public capabilities by selected area	ETag and published version; no inferred global support.
POST /v1/places/nearby	Guest; coordinate/category/radius search	50 results; signed cursor; 200 with coverage metadata.
POST /v1/places/search	Guest; bounded text + area	200-character text; 50 results; no unconstrained global scan.
GET /v1/places/{id}	Guest; public place and provenance	404 unknown; canonical ID for merged place.
POST /v1/routes	Guest; supported start/end and mode	Exactly two points initially; <= 100 km straight-line span and fully supported routing area.
GET /v1/content/{country}/{locale}	Guest; published country/emergency content	ETag, version, verification and review dates.
POST /v1/weather	Guest; coarse area weather	Cached provider snapshot and as-of time.

Method and path	Caller and behavior	Key limits/status
GET /v1/fx	Guest; latest approved base/rates dataset	Same-dataset conversion only; indicative label.
GET /v1/packs/{area}/manifest	Guest; signed active-version pointer	Short CDN TTL; immutable versioned signed manifest/assets; higher publication version on rollback.
POST /v1/accounts/resolve	Valid provider credentials; resolve/reserve account home region	No Local session required; authenticated minimal directory result; allowed hosts only.
POST /v1/me/sessions/bootstrap	Valid provider token and trusted session/authentication evidence	Atomic cutoff/epoch check; 201 new, 200 existing active binding, 401 stale evidence, 409 incompatible state.
GET /v1/me/sessions	Consumer; own active/recent sessions	Minimal device/time metadata; no credentials; bounded results.
GET /v1/me/saved	Consumer; own consistent snapshot	snapshotToken, generation, highWaterSequence; bounded home-region pagination.
GET /v1/me/saved/{placeId}	Consumer; own canonical state and strong ETag	Retained tombstone returns saved:false and version; 404 only if never present or no retained record.
PUT /v1/me/saved/{placeId}	Consumer; create or restore own save	Idempotency-Key; If-None-Match for new or If-Match version.
DELETE /v1/me/saved/{placeId}	Consumer; tombstone own save	Idempotency-Key and If-Match; version returned.
GET /v1/me/changes?cursor=...	Consumer; own ordered change feed	<= 200 changes; opaque cursor; 410 requires full sync.
POST /v1/reports	Guest or consumer; correction report	<= 2,000 text characters; no attachments in MVP; 202 receipt.
POST /v1/me/sessions/revoke	Consumer; chosen own session/logout-all	Recent auth for revoke-all; no other-owner IDs.
POST /v1/me/export	Consumer; asynchronous account export	Recent auth; authenticated download, no email attachment.
GET /v1/me/exports/{jobId}	Consumer; own export job status	Live authorization; job state and safe failure code.

Method and path	Caller and behavior	Key limits/status
GET /v1/me/exports/{jobId}/download	Consumer; download own ready export	Live authorization; 15-minute grant; revoke on security/account transition.
GET /v1/deletions/{receiptId}/status	Narrow deletion status token	Status/deadline only; no profile or restored account session.
POST /v1/deletions/receipt-recovery	Valid provider identity plus original deletion key	Existing receipt recovery only; cannot initiate deletion or restore account access.
DELETE /v1/me	Consumer; account deletion workflow	Recent auth, idempotency; 202 with status receipt.

Sections 22 and 23 specify the regional/account wire and recovery contracts. The implementation OpenAPI/ADR handoff MUST encode them and record the selected provider's integration details. The app accepts regional hosts only from its signed allowlist. Session bootstrap has no existing Local-session requirement but still enforces token validation, abuse limits, account state and region restrictions. Error bodies follow RFC 9457 with type, title, status, safe detail, instance/request ID and an application code. Never expose SQL, stack traces, token contents or precise location in errors. [S9]

Use 400 for malformed input, 401 for missing/invalid authentication, 403 for policy refusal, 404 for missing or non-owned private objects, 409 for idempotency mismatch or domain conflicts, 412 for stale If-Match, 413 for oversized input, 422 for unsupported route/coverage, 428 for missing required conditional headers, 429 for throttling and 503 for dependency unavailability. Save mutation success and 412 responses include canonical state/version or direct the client to the single-item read endpoint. A valid no-results search is 200 with an empty array. Include Retry-After for temporary throttling/outage and do not retry permanent validation/auth failures.

Abridged nearby response illustration; Section 22.2 defines the complete required schema:

```
{
  "datasetVersion": "city-release-20260924-01",
  "coverage": {"areaId": "approved-city-id", "supported": true},
  "items": [{
    "id": "place-uuid", "name": "Example Place",
    "category": "pharmacy", "distanceMeters": 420,
    "hours": {"status": "unknown", "raw": null},
    "source": "OSM", "sourceUpdatedAt": "2026-09-23T00:00:00Z"
  }],
  "nextCursor": null,
  "partial": false
}
```

12 Concurrent writes and offline synchronization

The private database is authoritative for synchronized saved state. Local state is optimistic and shows pending/conflict/error status. Separate public pack data from encrypted account-specific SQLite data. Each account switch changes private storage context and removes the previous account's tokens and private cache; never upload one account's pending operations into another account.

12.1 Durable write transaction

For each save/delete: validate the token, begin a transaction, lock the account row, and recheck active account state, bound session, revocation and auth_epoch against authoritative data. Reserve the scoped idempotency record, lock account_sync_state, validate snapshot generation and saved-place preconditions, allocate the next account sequence, apply the mutation with that sequence as its version, append the change/outbox event, record the result and commit. Revocation/deletion and mutations use the same account lock and lock order: no new mutation commits after a revocation/deletion transition has committed. Revalidate authorization before returning a stored idempotency result. Return success only after commit. Keep the transaction short. The per-account sequence lock serializes that user's changes without globally serializing all users.

Use a random operation ID as Idempotency-Key; scope it to owner, method and canonical path. Hash the normalized request including semantic preconditions and base snapshot generation. Concurrent duplicates wait for the same transaction or receive a retryable in-progress response. An identical retry returns the original result even if its original If-Match is now stale; a different payload/precondition with the same key returns 409. Retain deduplication results for seven days by default. Beyond that window the client must rebase against server state rather than blindly replaying an old operation.

Do not use a bare global database sequence as a commit-ordered sync cursor: a later sequence can commit before an earlier transaction. The account lock and transaction above preserve commit order for each account. The change-feed reader returns committed rows up to a stable high-water mark. The first page of an initial snapshot returns snapshotToken, generation and highWaterSequence. Subsequent pages use that token; the final page supplies the change-feed cursor for the same snapshot. Create the bounded materialized snapshot from one consistent database read and store it in approved home-region private storage; do not hold a transaction open across HTTP pages. Apply the 15-minute/two-active-snapshot limits in Section 22. Tokens expire explicitly; incomplete snapshots never replace the local canonical state.

12.2 Conflict and deletion policy

Use server-assigned monotonically increasing object versions, never device wall-clock timestamps, for conflict detection. Two devices with the same base version cannot silently overwrite each other. On 412, fetch current state and show the conflict or apply a documented same-intent convergence rule. Deletes create tombstones; a stale offline add does not resurrect a deleted save. A deliberate re-add requires the current tombstone version.

Every mutation carries its base snapshot generation and storeEpoch; validate both inside the write transaction. storeEpoch distinguishes private-data lineages after restoration/promotion as defined in Section 23.3. Before purging deletion/version fences, advance that account's generation atomically. Reject earlier-generation mutations/cursors with 410 SYNC_RESET_REQUIRED. Full reconciliation must not automatically turn pre-reset operations into new intent. Assign saved-object versions from the monotonically increasing account sequence; never restart a version at 1 after recreation.

Retain change-feed rows and save tombstones for 90 days by default. A device beyond the cursor retention window receives 410 and must perform a full snapshot sync before submitting pending changes; reconcile against current versions and user intent. Account deletion is terminal for that account ID and rejects all future sync, regardless of tombstone expiry. Bound local operations and storage; compact repeated operations on the same place only without changing their meaning. Limits are 10,000 saves/account and 1,000 queued operations/device, with visible recovery/export guidance when reached.

12.3 Queue semantics

Deliver outbox events at least once. Consumers record inbox deduplication and business effects atomically in their own database. An event includes event_id, aggregate ID/version, schema version, event type, region and timestamp; include only the minimum private payload needed. Reject/reconcile stale aggregate versions, retry transient errors with jitter, and send poison events to a dead-letter queue after a bounded number of attempts. Alert on oldest-message age, outbox lag and dead letters. Do not promise exactly-once delivery across services.

13 Secure offline packs

Public city packs contain POIs, licensed vector map tiles/styles/fonts, coverage boundaries and reviewed content. They contain no accounts, tokens, saved-place ownership or travel history. Choose a tested React Native-compatible map renderer with an explicitly licensed offline tile pipeline; pin and validate native SDK versions on iOS and Android. OSM data licensing does not grant unlimited use of OSM Foundation public tile services. Bulk/offline download from those public raster or vector services is prohibited. [S5-S7]

Build packs from a published immutable dataset. The manifest includes area/version, schema compatibility, min/max app versions, creation time, source and review timestamps, per-file compressed/uncompressed lengths, SHA-256 hashes, license/attribution records, signing key ID and signature. Use the exact JWS envelope and separate trust-root/release-signer lifecycle specified in Section 23.4; verify signed bytes before parsing. Trust approved signing public keys bundled in the app, with a separately authenticated key rotation/revocation mechanism. Keep signing authority out of public serving containers.

Signed metadata also includes issued_at and expires_at. Verify expiry, monotonic version, trusted key chain and signature before activating a newly downloaded pack. Maintain highest accepted version and last trusted time; never reduce either from an untrusted device clock. Establish fresh time using an authenticated online exchange with a trusted endpoint, not just the date in a potentially replayed manifest. If freshness cannot be established, postpone activation and retain the last trusted pack. Test clock rollback, reinstall, expired metadata and key rotation/revocation. Metadata expiry governs new activation; it does not erase previously trusted emergency fallback. Content review_due is separate.

Download to a staging directory with resumable byte ranges and network/power controls. Verify manifest signature, allowed version, lengths, hashes and schema before activation. Reject absolute paths, traversal, symlinks, duplicate names, unexpected files, excessive compression ratios, oversized row counts and invalid coordinates. Enforce a disk quota and decompression budget. Preflight free space for current pack, new pack and temporary files; never assume download size equals installation size.

Run SQLite integrity and content compatibility checks, then switch the active-pack pointer atomically. Preserve the last known good pack until the new one opens successfully. A killed process, battery loss or failed signature must leave the previous pack usable. Delete staging data safely on recovery. Signed emergency withdrawals carry a higher version; an intentionally rolled-back dataset must be republished under a higher manifest version to avoid downgrade ambiguity.

Freshness is feature-specific. POIs show source age; weather/FX show their own as-of times; emergency records show verification/review status. Ordinary age/expiry does not erase the last trusted emergency fallback, but expired content is never labelled newly verified. A subsequently authenticated security revocation is different: quarantine affected installed artifacts and select an unaffected trusted fallback under Section 23.4. An offline device cannot learn about a newly revoked key or content record until reconnecting; disclose that limitation and refresh manifests whenever connectivity returns. Emergency numbers for enabled countries are also shipped in an independently reviewed app bundle so first install does not depend on downloading a city.

14 Ingestion routing and provider data

14.1 Geographic publication pipeline

Download approved regional OSM extracts/replication updates through isolated workers. Store source hashes, timestamps, license and import configuration. Validate bounds, source identities, types, duplicate rates and abnormal record-count changes before normalization. Preserve raw hours and localized names; curated corrections are a versioned overlay with reviewer/source provenance. Do not overwrite licensed provider fields with incompatible OSM provenance.

Import into staging tables, build indexes, run data-quality and golden-query checks, produce graph/tile/pack artifacts, then atomically publish the release pointer. Keep the previous compatible release for rollback. Serialize publication per area using database state/version conditions and a lease with a fencing token. A crashed or expired publisher must not overwrite a newer release. Event retries re-run safely against the same dataset ID and content hashes. No user request queries Overpass or waits for an import/build. A self-hosted Overpass instance is optional internal analysis infrastructure, not an MVP serving dependency.

14.2 Routing semantics

OSRM travel behavior is set by the profile used during graph preparation. Build and deploy walking and driving graphs separately; changing the URL profile string does not turn a car graph into a walking graph. Record graph source date, profile version and supported polygon. The routing gateway dispatches to the correct pool and rejects unsupported areas/modes. [S10]

Bound requests to two points initially; disable unrestricted matrices, matching and long waypoint lists. Set a request deadline, cancellation, response-size limit and concurrency budget per pool. Return graph version, route distance/duration, geometry and source age. Do not call duration a live-traffic estimate. A route is not a guarantee of accessibility, safety, road opening or emergency access. If a route crosses a graph seam, border or unsupported area, reject it clearly or hand off to an explicitly chosen external navigation app after a user action. Do not silently join disconnected graphs.

14.3 Utilities and enrichment

Use provider adapters with schema validation, per-provider quotas, timeouts and circuit breakers. Keep credentials server-side. Weather keys use coarse cells, units and locale; never send account IDs. FX is one versioned dataset with a single source/as-of timestamp; never combine rates from inconsistent bases or dates. Default refresh proposals are weather every 10 minutes and FX hourly; legal/provider retention limits override these operational settings. If the actual tariff cannot support hourly refresh, change the freshness contract before launch.

Provider selection and price verification remain procurement gates. Do not assume `exchangerate.host` or any alternative offers a suitable free tier. Review ODbL obligations for derivative databases and offline distribution, including any required notices and database access/share-alike duties; separate SQL tables alone do not prove legal independence of mixed data. [S13]

Future enrichment needs a field-level matrix for display, cache duration, offline storage, attribution, deletion, mixing and region-specific terms. A generic instruction to cache aggressively is insufficient and may violate the chosen provider's terms.

15 Performance limits and failure behavior

Allocate independent concurrency pools for DB work, OSRM, utilities and identity so one slow dependency cannot consume every request thread. Use bounded executor queues and connection pools, request deadlines and cancellation. Do not hold database connections during HTTP calls. Apply overload admission before costly work; a controlled 429/503 is preferable to unbounded queues and process failure.

Initial budgets to tune under load: discovery end-to-end service deadline 800 ms with a 300 ms SQL timeout, private mutation deadline 1.5 s with a 500 ms SQL timeout, routing deadline 2.5 s including gateway overhead, utilities deadline 1 s. Route p99 SLO includes network overhead beyond the service budget. Set dependency timeouts from measured distributions. Retry at one designated layer only, at most once inside the remaining deadline for safe transient failures; never retry non-idempotent mutations without the established idempotency contract. Use exponential backoff with jitter and a fleet retry budget. [S11]

Control	Initial policy	Failure behavior
API abuse limit	Nearby 60/min, routing 10/min, reports 5/hour per installation signal plus network limits	Tune for shared NATs; installation IDs are spoofable, not identity. Edge aggregate limits remain mandatory.
Private writes	60/min/account with bounded burst	429 and Retry-After; preserve pending client operations.
Payload	32 KB standard JSON body; explicit smaller schemas where possible	413 before expensive parsing; bounded decompression and nesting.
DB connections	Example: 10 replicas x 10 connections = 100; reserve headroom	Sum API/worker/admin pools below approved database connection budget.
Public candidate cache	Dataset/area/cell/radius bucket/category/locale/schema key; 5 min plus jitter	Single-flight refresh, bounded candidate sets and negative caching <= 30 s.
Private HTTP responses	no-store; never shared-CDN cached	Account-scoped local cache only; purge on switch/logout.
Weather stale data	10 min target, up to 60 min stale if terms permit	Show age/stale status, then unavailable.
FX stale data	1 hour target, up to 24 hours stale if terms permit	Indicative estimate with date, then unavailable.
Signed public artifacts	Immutable versioned paths and hash	Long-lived CDN caching; short manifest-pointer TTL and purge support.

Redis failure must not remove ownership/session controls. Public reads may fall back to the database only within a bounded fallback concurrency budget; otherwise serve a safe local/stale public response or 503. Keep edge and local emergency abuse protection if a distributed limiter is unavailable. Reject sensitive operations when their required security state cannot be checked. Database failure leaves downloaded discovery/emergency content available; new saves remain pending. Identity failure blocks new sign-in/refresh but does not block guest discovery or local emergency content. OSRM failure disables fresh routes without hiding the destination. Never retry all modules because one utility failed.

Use read replicas only for public or explicitly eventually consistent data. Saved-place reads after a successful write go to the writer or require a replication-position barrier. Cache invalidation is by immutable dataset version for public data and account/version for any private internal cache. Avoid unbounded high-cardinality metric labels such as user IDs, coordinates or search strings.

16 Emergency integrity and privacy

16.1 Emergency publication workflow

Each emergency record includes country/area, service type, telephone dialing format, language, official source URL, source retrieval date, verification evidence, author, independent reviewer, version and review_due. Workflow is DRAFT -> IN_REVIEW -> APPROVED -> PUBLISHED -> SUPERSEDED/WITHDRAWN. Enforce valid transitions and different author/reviewer identities in the service and database transaction. No support report or unreviewed import changes published emergency content.

Approval binds the canonical payload hash, version, jurisdiction and locale. Publishing rechecks transactionally that this exact hash has independent approval and remains eligible. Publishers cannot approve or modify it. A payload change creates a revision and invalidates prior approval; pack builders accept only published approved hashes. Rollback republishes an approved payload under a higher release version with audited authorization. Signatures prove artifact integrity, not correctness of the emergency information.

Review cadence is every 30 days and immediately on an official change alert or credible correction. A trained content lead owns the queue and escalation. Only approved records enter the signed manifest and app-bundled fallback. Provide rapid withdrawal and a tested version rollback. An emergency correction's 15-minute distribution target begins after human approval; it is not a promise that an offline phone receives the change.

Users can manually confirm/change country; do not choose solely from SIM, IP or an old GPS fix. Always show the selected jurisdiction and data age. Open the platform dialer on explicit user action; do not place calls or send location automatically. The app is not an emergency dispatch service. Nearest facilities are selected independently of commercial ranking and clearly distinguish a curated emergency-capable facility from an unverified general POI. Do not record individual emergency-screen events with identity or coordinates; use synthetic tests and coarse aggregate reliability measurements.

16.2 Data minimization and retention defaults

Data	Collection and storage rule	Proposed retention
Precise live coordinates and route points	Request memory only; no database, traces, body logs or crash payloads	No intentional server persistence. Infrastructure configuration must enforce this.
Account and saved places	Home-region private database; encrypted backups	While account is active; user deletion workflow applies.
Public packs	Public data only, on-device/object storage	Versioned according to data/license policy and device quota.
Request metadata	No body/query content; shortened IP or keyed rotating abuse signal where possible	Operational logs 14 days; raw edge IP at most 7 days unless justified.
Security and editorial audit	Minimal actor/action/object metadata; no GPS or credentials	90 days security logs; publication provenance while content is used plus approved archive period.
Crash reports	Allowlisted fields and scrubbed device/user identifiers	30 days; strict access and verified vendor configuration.
Save changes and tombstones	Account-local sync only	90 days; expired cursor forces rebase.
Backups	Encrypted regional copies; tightly controlled restoration	35 days rolling; deletion ledger reapplied after restore.

These defaults require jurisdiction and operational review; they are not legal retention mandates. Country-specific obligations override the table before deployment. In particular, assess India's CERT-In directions on covered entities, ICT log retention/location and incident reporting before using the proposed short log retention. Retain only the required security metadata; a longer security-log duty is not a reason to log precise travel coordinates. Location permission is not blanket consent for analytics, advertising or background tracking. Keep travel history off and unbuilt in MVP. Do not monetize precise-location trails. Publish a clear privacy notice explaining processors, purposes, retention, rights and transfers; test data export/deletion end to end. Account deletion disables access promptly, removes active data/processor copies within the published period (internal target no more than 28 days, with jurisdiction-aware legal deadlines and exceptions), and expires backup copies on schedule. Preserve only documented legally required records, with purpose and access restrictions. Do not retain a deleted user's email merely to maintain a sync tombstone.

16.3 Country legal review gates

Before each country's launch, a qualified privacy owner determines applicable national/subnational rules, effective dates, age/child access requirements, lawful basis/consent, rights handling, processor contracts, transfers and incident notice duties. India, the UK, the US, Australia and Canada do not share one privacy regime. Geography-based hosting alone does not establish compliance: identity, support access, telemetry, CDN logs and backups also create processing/transfer questions. The official sources below support the applicability review and must be rechecked before release. Treat minors and consent age as a blocking product decision; do not claim a general consumer sign-up screen solves it.

These are applicability gates, not compliance conclusions or blanket residency requirements. Recheck at release; each jurisdiction's approved obligations override Section 16.2 defaults.

Market	Required review and official source
India	Validate phased DPDP commencement, notices/rights and transfers. Assess CERT-In log-retention, reporting and log-location obligations before adopting short retention defaults. MeitY ; CERT-In .
UK	Assess UK GDPR scope, rights and restricted transfers; recheck guidance affected by the Data (Use and Access) Act. ICO rights ; ICO transfers .
US	Map applicable federal/state rules and thresholds. California treats precise geolocation as sensitive; assess deletion and SDK sale/sharing implications. California AG .
Australia	Determine APP coverage/exemptions; review overseas disclosure and retention. OAIC coverage ; OAIC transfers .
Canada	Assess PIPEDA and provincial laws, including Quebec; evaluate interprovincial/international processing and required assessments/contracts. OPC applicability ; Quebec CAI .

Seed the emergency editorial registry from these official sources. They do not independently certify local facility coverage. Preserve source URLs, locality, verification evidence and two-person approval; never place test emergency calls.

Market	Official seed and scope check
India	MHA ERSS ; verify state/UT applicability.
UK	GOV.UK emergency guidance ; review territories and accessibility options.
US	National 911 Program ; verify local non-voice availability separately.
Australia	Triple Zero ; review current carrier/accessibility guidance.
Canada	CRTC ; model territorial/local service exceptions.

17 Operations security and recovery

Define services, dashboards and on-call ownership before launch. Use OpenTelemetry-compatible traces with request IDs, route templates, status and latency; keep coordinates, tokens, queries and personal saved-place payloads out of all telemetry. Instrument queue age, graph version, ingest lag, source freshness, cache hit ratio, DB saturation, pool rejection, pack verification failures, crash-free sessions and sync conflicts. Measure emergency availability through synthetic and local-device tests.

Alert on multi-window error-budget burn, sustained valid-request rejection, rising p99, exhausted connections, failed backups, old queue messages, dead letters, signature failures and overdue emergency reviews. Page an owner for actionable service/safety failures; route ordinary content gaps to the staffed queue. A health check must distinguish process liveness from readiness. Graceful shutdown drains requests and completes or rolls back transactions before termination.

17.1 Delivery and environment controls

Separate dev, staging and production cloud accounts/projects, secrets, data and identity clients. Use synthetic/redacted test data. Infrastructure-as-code and migrations require review; production builds use lockfiles, dependency/container/secret scans, SBOMs and signed provenance. Deploy only immutable images from a controlled registry; use non-root containers, read-only filesystems where practical and minimal IAM. Keep signing keys in managed key/HSM services and rotate secrets without an app release. Security scan results require exploitability assessment; unresolved reachable critical/high findings stop launch unless an authorized documented exception is valid.

Use additive expand/migrate/contract database changes. Keep backend compatibility with the current and previous mobile release for at least a 90-day window, longer if adoption demands it. Publish server changes before clients depend on them. Canary API releases (5%, 25%, 100%) with automated SLO/error gates; roll back by image and feature flag while preserving schema compatibility. Mobile binaries cannot be instantly rolled back: stop store rollout, use reviewed remote kill switches and keep compatible server behavior. Kill switches cannot remove bundled emergency access.

17.2 Recovery objectives and drills

Scenario	Recovery target	Required proof
API replica loss	No acknowledged write loss; recovery ≤ 5 min	Terminate replica under load; valid requests meet degraded SLO budget.
Availability-zone loss	Private data RPO 0 for acknowledged commits where managed synchronous HA guarantees it; service RTO ≤ 15 min	Failover drill, pooled connection recovery and surviving capacity verified.
Regional private-data loss	RPO ≤ 15 min and RTO ≤ 4 hours only with approved replicated recovery design	Measured replication/restore drill and fencing; otherwise do not claim these targets.
Corrupt public dataset/pack	Switch to prior compatible release ≤ 15 min	Version-pointer rollback and client compatibility tests.
Accidental data deletion	Point-in-time restore and reconciliation	Restore to isolated environment, apply deletion ledger, prove integrity before cutover.

Enable encrypted point-in-time database recovery and object versioning. Test backups by restoring; successful backup jobs alone are not evidence of recovery. Run quarterly restore drills and a pre-launch region/zone exercise. Document incident severity, paging, containment, evidence retention, credential/key revocation, customer communications and jurisdiction-specific notification assessment. A declared regional failover must fence the old writer and record the recovery point before enabling writes.

18 Verification and release gates

The engineering lead maintains an evidence register linking each requirement to a test/runbook, owner, result, artifact version and date. Unit tests alone cannot close the security or reliability findings. Exercise real devices, realistic data and representative network conditions.

Gate	Required tests and pass condition	Accountable owner
G1 Identity and authorization	Cross-account IDs, mass assignment, invalid issuer/audience, expired/replayed tokens, session revocation, recovery and role escalation all rejected; guest emergency succeeds	Security/backend
G2 Mobile and local data	Keychain/Keystore checks, account switch isolation, deep-link hijack tests, logout, rooted-device risk review and scrubbed crash payloads	Mobile/security
G3 Input and abuse	SQL/XSS/SSRF/path traversal, oversized JSON/archives, parser depth, report spam and route exhaustion cannot bypass bounds	Security/platform
G4 Offline correctness	Airplane mode on first install and after download; disk full, kill during update, signature/hash failure, stale content and schema rollback retain safe behavior	Mobile/data
G5 Concurrent consistency	100 parallel duplicate mutations cause one logical change; two devices with same version conflict deterministically; old deletes do not resurrect; cursor paging loses no committed change	Backend/QA
G6 Data and safety	Each enabled city passes Section 3; all curated emergency records have independent review; wrong-country and outdated-location flows tested	Content/data
G7 Load and endurance	60 min at stage sustained load, 10 min at greater of declared burst or 2x sustained, 8 hour soak; cold/warm caches, route-heavy mix and 80% load in one region; documented capacity/admission outcomes	Performance/platform
G8 Dependency failure	Kill API/OSRM/cache; inject provider latency, database failover and queue duplication; prove graceful degradation and no retry storm	Platform/backend
G9 Disaster recovery	Restore verified backup, fence/promo exercise if regional DR claimed, apply deletion ledger, meet documented RTO/RPO	Platform
G10 Privacy and licensing	Inspect actual logs/exports; exercise deletion; verify each provider/pack field license, attribution and regional processing contract	Privacy/product
G11 Accessibility and locale	Screen readers, large fonts, permission denial, slow GPS, scripts, units, DST and timezone cases on supported devices	Mobile/QA
G12 Release and operations	Signed artifacts, reviewed migrations, runbooks, pager ownership, dashboards, budget alarms and canary/rollback demonstrated	Engineering lead

Load reports state hardware, regions, dataset/graph size, app version, traffic mix, arrival rate, concurrency, payload sizes, cache hit ratio, mean/p95/p99, failures and saturation. An idle demo or average response time does not establish scale. Test supported-city dense centres and worst-case spatial queries. Repeat a failed/newly affected gate after fixes; do not reset passing unrelated evidence without reason.

Stop release for incorrect emergency dialing/content, cross-account access, credential/location leakage, corrupt pack activation, lost acknowledged private writes during normal or zone-failure operation, recovery loss exceeding the declared RPO, unresolved dangerous routes or an untested restore. A feature can launch later behind a disabled capability flag; a safety defect cannot be hidden behind a general production-ready label.

19 Delivery plan and cost controls

19.1 Implementation work packages

Sequence	Work and outputs	Exit condition
P0 Foundation decisions	Choose five pilot cities, regions, IdP, tiles/provider contracts, traffic budget and privacy model; create ADRs and data samples	Country/city feasibility and procurement gates signed off.
P1 Secure platform	IaC, isolated environments, CI, managed state, identity integration, policy middleware, logging filters and backups	G1 baseline, G3 infrastructure checks and a successful restore.
P2 Discovery data	Versioned ingestion, PostGIS schema/queries, coverage catalogue, map rendering and local public storage	Golden data/query cases and city certification evidence.
P3 Private and offline	Saves, idempotency, ordered sync, encrypted private store, signed packs and deletion workflow	G2, G4 and G5 pass; no account crossover.
P4 Routing and content	Independent mode graphs, content review/publish, emergency bundle, provider adapters	G6 and mode/area route acceptance; utilities fail independently.
P5 Operational qualification	Load/failure/DR/security assessment, device matrix, accessibility and cost test	G7-G12 pass; critical/high findings closed for enabled scope.
P6 Controlled launch	Internal users, invited beta, one certified city per first country, then measured expansion	Each cohort meets SLO and content readiness; rollback remains available.

Parallelize mobile shell, platform and data feasibility after contracts are agreed. Do not promise a calendar schedule without named staffing, city data work and provider procurement. Needed functions are product/content, mobile, backend, data/GIS, platform and security/QA; one person may cover several functions but every gate has an accountable owner. A second person is mandatory for emergency content approval.

19.2 Budget model

The v6 estimate of approximately USD 100-335/month applies to an unverified small single-city configuration and must not be used as a five-country production budget. Prepare a dated provider calculator estimate from measured workloads. [S12]

Monthly cost = regional fixed HA services + API/worker compute + public/ private database storage and I/O + graph fleet/build compute + cache + identity monthly active users and authentication charges + CDN tiles/pack requests and egress + object storage + provider calls + logs/traces + backup/DR replication + security tooling/support. Add app store, tax, people and content verification costs separately. Map downloads and regional redundancy can dominate a quiet API's bill.

Track cost per 1,000 discoveries, 1,000 routes, GB delivered and active account. Cache-hit assumptions must be measured and license-compliant. Configure warnings at 50%, 80% and 100% of an approved monthly budget plus provider quota alerts and anomaly detection. Budget controls can pause background rebuilds or new pack

downloads with clear messaging; they must preserve local emergency access. Do not automatically run up unrestricted cloud capacity to preserve a nominal latency target.

20 Decision register and definition of done

Decision	Current engineering position	Required owner action
Architecture	Modular Spring app, replicated APIs; independent route/ingest/build workloads	Approve ADR and module boundaries.
Markets	Worldwide direction; initial India, UK, US, Australia, Canada	Select five launch cities and exact coverage polygons.
Scale	Beta 200 RPS; event design target 5,000 RPS	Confirm actual forecast, peak mix and budget; benchmark before capacity claims.
Cloud	AWS reference with regional account ownership	Approve regions, HA footprint and transfer/DR paths.
Identity	Managed OIDC, code+PKCE, device-session binding and replay-safe refresh	Select and prove provider capabilities, residency and recovery.
Offline	POIs, maps, reviewed content, saves and cached route viewing	Approve explicit exclusion of new offline route calculation.
Map and data	Licensed/self-hosted vector packs; OSM imported to PostGIS	Choose tested renderer/tile pipeline and record license evidence.
Routing	Separate walking/driving OSRM graphs and supported areas	Validate modes, memory, seam limits and local access quality.
Privacy	No persistent precise location or travel history in MVP	Approve retention, age policy, notices and jurisdiction-specific requirements.
Utilities	Adapters with approved quotas/freshness	Select weather/FX providers from current terms and measured cost.
Operations	SLO/error budget, on-call, restore and signed release gates	Name owners and demonstrate each runbook.

Engineering may implement from this final baseline. Resolve the remaining product, supplier and legal release inputs before exposing dependent capabilities. Public launch requires the signed release record in Section 24, including evidence for enabled capabilities, budget and country-specific content/privacy approval.

21 References and verification record

Source document reviewed in full: local-project-document-v6.md, sections 1-15. User scope update: worldwide expansion, first India, UK, US, Australia and Canada. External technical references checked on 24 September 2026. Project-specific defaults and architecture choices are this specification's baseline requirements, not claims made by the referenced standards. Traffic forecasts remain assumptions and SLOs remain test targets.

- [S1 OAuth security best current practice RFC 9700](#) - authorization flow and refresh-token replay protections.

- [S2 OAuth for native apps RFC 8252](#) - external user agents and native client constraints.
- [S3 OWASP MASVS](#) - mobile verification coverage.
- [S4 Spring Security JWT resource server](#) - issuer, signature, timestamp and explicit audience configuration.
- [S5 OpenStreetMap copyright and license](#) - attribution and ODbL requirements.
- [S6 OSM Foundation raster tile usage policy](#) - service usage and offline/bulk restrictions.
- [S7 OSM Foundation vector tile usage policy](#) - vector service usage and offline restrictions.
- [S8 PostGIS ST DWithin](#) - distance units and index-aware proximity filtering.
- [S9 HTTP problem details RFC 9457](#) - interoperable API error representation.
- [S10 OSRM profiles](#) - preparation-time routing profiles.
- [S11 AWS timeouts retries and jitter](#) - bounded retries and dependency deadlines.
- [S12 AWS Pricing Calculator](#) - prepare a dated estimate after region/workload selection.
- [S13 OSM attribution guidelines](#) and [ODbL legal FAQ](#) - review distributed database obligations, attribution and share-alike implications; attribution alone is not the entire license analysis.
- [S14 JSON Web Signature RFC 7515](#) - signed envelope representation and validation.
- [S15 JSON Web Algorithms RFC 7518](#) - ES256 algorithm definition.

Country-specific regulator and official emergency sources are linked directly in Section 16.3. Archive the exact source versions and effective-date assessment in the launch evidence register; links alone do not certify compliance.

22 Normative API field contracts

This section is the implementation baseline for the endpoints in Section 11. Generate the machine-readable OpenAPI definition and contract tests from these requirements as an implementation deliverable; neither is represented as an already tested application. The schemas below define required fields and constraints. Extra request fields are rejected unless the relevant version explicitly permits them; clients tolerate unknown response fields. Reject duplicate JSON keys, non-finite numbers and bodies outside the defined limits before business processing.

22.1 Common types and authentication context

Type or field	Required representation	Validation and authority
Object ID	Opaque UUID string	Generated by the owning service. UUID opacity is not authorization.
Version and sequence	Non-negative integer encoded as a decimal string	Avoid JavaScript integer precision loss; compare numerically, not lexicographically.
storeEpoch	Server-generated UUID for a regional private-data lineage	Changes on rollback recovery or writer promotion; never restored from an old database as current authority.
generation	Account snapshot-generation decimal string	Changes before deletion/version fences are purged.
Timestamp	UTC RFC 3339 string with explicit Z suffix	Source/authentication timestamps retain provider precision and verification metadata.
Coordinates	Object with latitude and longitude numbers	Latitude -90 to 90; longitude -180 to 180; finite; no inferred country authority.
Locale and units	Supported BCP 47 tag; metric or imperial	Unsupported locale falls back only through the published coverage policy.
Request ID	Server-generated trace identifier	Returned in X-Request-Id; never encode user ID, location or credentials.
Private context	Valid access token and trusted bound session	Account, roles, home region and session identity come from verified server state, never request ownership fields.

Requests carrying credentials use Authorization headers only. The app sends bearer credentials solely to signed-allowlisted identity/private hosts. Account-resolution requests are authenticated but precede Local session establishment. API schema examples use fictitious IDs and are not production records.

22.2 Discovery and public response schemas

NearbyRequest requires areald, origin, category and radiusMeters; locale, limit and cursor are optional. Limit defaults to 20, maximum 50; radius is 100-10,000 metres. Category enum is hospital, pharmacy, police, atm, restaurant, cafe, hotel, transit_stop, supermarket or fuel. SearchRequest instead requires query and areald, with optional origin for distance ordering; query is 1-200 normalized Unicode characters. Cursor requests must repeat the same semantic query; the cursor binds its query hash. Unknown categories, mismatched cursors or unsupported coverage are rejected with a stable error code.

PlaceResponse requires id, category, localized name, location, countryCode, datasetVersion, sourceUpdatedAt and freshness. Timezone and raw opening hours may be null when unverified; hours.status is unknown unless safely evaluated for the place's local time. distanceMeters is present only when computed for a supplied origin. Aliased IDs return canonicalId; withdrawn places return availability=withdrawn with minimal historical identity instead of pretending they remain open. Public search lists never contain account saved flags.

NearbyResponse requires items, datasetVersion, coverage, generatedAt, freshness, partial and nextCursor (nullable). coverage includes areald and capability flags; freshness includes sourceUpdatedAt and status=fresh, stale or unknown under that dataset's published policy. A response marked partial includes reason codes. Empty supported results remain HTTP 200. HTTP 422 COVERAGE_UNSUPPORTED is distinct from zero nearby places. No unsupported country receives a verified coverage claim.

RouteRequest requires areald, origin, destination and mode=walking or driving. RouteResponse requires graphVersion, profileVersion, mode, distanceMeters, durationSeconds, geometry, sourceUpdatedAt and coverageAreal. Geometry is GeoJSON LineString with longitude/latitude pairs. Bound the encoded JSON response to 2 MB; reject excessive results with ROUTE_TOO_COMPLEX rather than silently corrupting geometry or dropping instructions. Requests spanning more than 100 km straight-line distance or leaving supported coverage are rejected for the first release. Route data may be cached privately on-device with an age label; it is not a live-traffic or safety guarantee.

ContentResponse requires recordId, version, countryCode, geographicScope, locale, publishedAt, verifiedAt, reviewDue, sourceReferences, status and payload. An emergency payload distinguishes national dialing guidance, local exceptions and verified facility information. The app must be able to show the selected jurisdiction before it offers a dial action.

22.3 Account directory and session endpoints

POST /v1/accounts/resolve accepts no asserted account ID. It accepts an optional requestedHomeRegion for a first registration only, plus a registration Idempotency-Key. The server authenticates the provider subject, applies the approved residency/transfer policy, and returns the existing mapping or reserves one new mapping. A client preference cannot overwrite an existing home region. ACTIVE returns 200 with accountId, homeRegion, privateApiOrigin and routingEpoch in an authenticated routing response. PENDING returns 202 with registrationId and Retry-After; retrying resolve obtains status without creating another account. RESTRICTED/DELETION_PENDING bindings reject new registration under that same lifecycle until the deletion policy permits a deliberate fresh registration.

POST /v1/me/sessions/bootstrap accepts optional bounded deviceDisplayName and platform metadata only. Session identity, auth_time, account ID and epoch are resolved from validated provider evidence and home-region state; none can be submitted as trusted JSON. Return sessionId, accountId, homeRegion, storeEpoch and the server's session expiry. SessionId is a display/revocation handle, not an authentication secret. Authentication continues to use the provider access token and its verified session binding.

POST /v1/me/sessions/revoke accepts exactly one of sessionId or allSessions=true. Both operate only on the authenticated account. allSessions requires recent authentication. The server commits local revocation and a durable provider-revocation task before acknowledging; provider status is exposed separately as pending or confirmed. Consumers cannot call staff session endpoints. Automated recovery/reuse events follow Section 7 and never trust an unsigned client assertion.

22.4 Saved places and synchronization wire rules

PUT /v1/me/saved/{placeld} represents saved=true; DELETE represents saved=false. Both require Idempotency-Key, X-Store-Epoch and X-Sync-Generation. New records require If-None-Match: *; an existing record or tombstone requires its exact strong If-Match ETag. The initial implementation accepts no optional free-text notes or caller-supplied ownership fields. Reject a missing conditional header with 428, an outdated version with 412, a lineage/generation mismatch with 410, and a reused idempotency key with different semantics with 409.

An ETag binds storeEpoch, account generation, object ID and version and is quoted according to HTTP syntax. A first create returns 201; updates and deletes return 200 with SavedState, including placeld, saved, version, updatedAt,

storeEpoch and generation. A delete response preserves the tombstone's new version; DELETE of a never-present object returns 404 and does not create a tombstone. A no-op new operation returns the current state without allocating another change event, but still records its own idempotency result. Retrying a committed key returns its recorded response only after current authorization, lineage and generation checks pass. After an epoch/generation reset, return 410 even if an old idempotency result remains stored.

GET /v1/me/saved/{placeId} returns the same SavedState and strong ETag. An unknown object without a retained tombstone returns 404. GET /v1/me/saved defaults to 100 records/page, maximum 200. Materialize a bounded consistent account snapshot in the home region rather than holding a database transaction across mobile requests. The snapshot contains current saved records, storeEpoch, generation and highWaterSequence. Its private snapshotToken expires after 15 minutes; at most two active materialized snapshots are allowed per account. Snapshot storage is encrypted, account-bound and automatically purged on expiry, logout-all and deletion.

The first snapshot page returns snapshotToken, snapshotExpiresAt and highWaterSequence; later pages require the token and an opaque page cursor. Only the final page returns nextChangeCursor. Install the complete snapshot atomically into local staging; a truncated or expired download never replaces the active local state. Retain local pending intents separately for reconciliation. A snapshot contains currently saved records; conflict resolution reads retained tombstones through the single-item endpoint.

GET /v1/me/changes returns items ordered by committed account sequence, plus nextCursor, hasMore, storeEpoch and generation. Each item has sequence, entityType=saved_place, placeId, saved, version and updatedAt. Pages default to 100, maximum 200. Fix an upper committed sequence at the first page of each delta paging session and bind later pages to that upper bound. The final cursor advances to that bound; later commits belong to the next session. An empty page returns a valid unchanged/high-water cursor and hasMore=false. Cursors are integrity-protected and account-, lineage- and generation-bound, with a maximum history age of 90 days. Signature failure, another user's cursor or a modified query is never accepted. A valid but expired/reset cursor returns 410 SYNC_RESET_REQUIRED; the client stages a new complete snapshot.

22.5 Asynchronous jobs and stable errors

POST /v1/me/export returns 202 with jobId and statusUrl. GET /v1/me/exports/{jobId} is owner-scoped and returns a state of queued, running, ready, failed, expired or cancelled; failures include a safe failure code. When ready it supplies a same-origin authenticated download endpoint. Download authorization is checked against live account/session status, including after job creation. Download grants expire after 15 minutes and generated exports are deleted within 24 hours. Do not expose public object-store URLs that bypass revocation. Export includes account-owned data and machine-readable provenance, excluding staff-only security records and other users' information.

DELETE /v1/me returns 202 only after the account has entered DELETION_PENDING and its sessions can no longer mutate private state. Return a deletion receipt and narrowly scoped status token; the token is generated randomly, stored hashed and sent only in a header to GET /v1/deletions/{receiptId}/status. It reveals only workflow status and due date, no account profile. Rate-limit it, prohibit all other uses and expire it after the deletion process and applicable acknowledgement period. This lets the user check deletion without restoring a revoked login session. A queued job is not reported as completed erasure.

If the deletion command commits but journal acknowledgement or its response is lost, the client calls POST /v1/deletions/receipt-recovery with a cryptographically valid provider identity and the original deletion Idempotency-Key. This narrow exception does not require the revoked Local session. It resolves only the caller's already recorded deletion command, verifies the original command hash, and returns pending status or reissues that receipt with a fresh random hashed status grant after durable journal acknowledgement. It cannot create a deletion, read profile data, reopen the account or authorize other endpoints. Never retain a raw status token in an

idempotency response log; replace the previous grant on recovery. Test journal timeout, lost 202, replay from another subject and repeated recovery. If the provider identity can no longer be proven, use the published privacy-support verification process; do not relax authentication.

Correction reports return reportId and receivedAt. Reports cannot change publication status. For guests, do not provide a list/history API that can enumerate submitted reports. Currency responses include source, asOf, baseCurrency and rates as decimal strings; conversion rounds for display only. Weather includes coarse area, observedAt/provider forecast time, units and stale status, with optional fields represented explicitly.

All errors use application/problem+json and the HTTP status contracts in Section 11. Stable application codes include VALIDATION_FAILED, AUTH_REQUIRED, AUTH_REAUTH_REQUIRED, ACCESS_DENIED, OBJECT_NOT_FOUND, VERSION_CONFLICT, IDEMPOTENCY_MISMATCH, SYNC_RESET_REQUIRED, SNAPSHOT_EXPIRED, COVERAGE_UNSUPPORTED, ROUTE_TOO_COMPLEX, RATE_LIMITED and DEPENDENCY_UNAVAILABLE. Clients branch on code/status, never localized detail text. A private conflict body cannot disclose another owner's state. Server timeout does not prove a mutation failed: retry the same idempotency key, then reconcile if its retention window has elapsed.

23 State transitions and recovery contracts

23.1 Account registration without distributed transactions

The control directory owns global identity uniqueness. Its registration record contains registrationId, identity binding, accountId, homeRegion, routingEpoch, state, lease/fencing token and timestamps. Valid states are PENDING, ACTIVE, MIGRATING, RESTRICTED, DELETION_PENDING and TOMBSTONED. A registration reservation and its provisioning outbox entry commit atomically. One idempotent worker creates the home-region account and confirms its identity/region before conditionally activating the exact reservation. A lost acknowledgement replays the same registration ID; it never allocates a second account.

A worker lease lasts 60 seconds and is renewed during active processing. Only the current fencing token may acknowledge activation. An overdue reservation is reconciled after five minutes by checking the regional account, then completing or quarantining it. Do not expire a reservation into an unclaimed identity merely because the network is down. A permanently failed first registration releases its binding only after an audited reconciliation proves there is no active regional account or unprocessed provisioning event. While unresolved, return a recoverable pending/support state rather than creating a duplicate in a different region.

Accounts resolve to their existing region while traveling. Cross-region migration is disabled in the first release. A future migration must freeze writes, copy and verify private state, advance routing authority, fence the prior writer and force a client rebootstrap. Directory failure blocks new registrations and migrations; cached authenticated routes can reach established accounts subject to local authorization. Registration errors do not disclose other people's identities or emails.

23.2 Account and device lifecycles

Account states are ACTIVE, SUSPENDED, DELETION_PENDING and DELETED. Only ACTIVE may mutate. Suspension/recovery/deletion locks the same account authority used by mutations, changes security authority where required, and emits a durable audit/outbox record. DELETED is terminal for that account ID. Re-registration after an allowed completed deletion requires a deliberate user request and provider authentication later than the deletion cutoff, then creates a new account ID and clean generation; no old save queue or credentials can attach to it.

Local guest saves use an encrypted installation-scoped store and remain available without an account. After sign-in, ask whether to import those guest saves; submit bounded ordinary authenticated save operations using current server versions. Guest import does not upload location history or merge arbitrary prior-account data. Clear the guest copy only after user choice and durable acknowledgement. An account logout warns about unsynchronized data, then deletes account-scoped keys/cache/queue as specified; public packs remain. The next sign-in starts from a fresh authenticated snapshot.

A device that loses its refresh response keeps a serialized refresh state and follows the provider's documented bounded recovery behavior. It must not race multiple refreshes or retry an obsolete refresh token indefinitely. If the replacement cannot be recovered safely, stop synchronization and require sign-in; pending local intents remain protected until the user chooses to discard or reauthenticate. Do not downgrade to long-lived access tokens or disable replay detection to avoid a login prompt.

23.3 Promotion and restored database lineage

Each private-data region uses an external recovery authority with a durable, monotonically advancing promotion record. `storeEpoch` is a fresh UUID for every promotion or point-in-time rollback recovery and is carried in cursors, object ETags, idempotency scope, snapshot tokens and client mutation headers. It cannot be recovered solely from the database being restored. Sequence integers can legitimately rewind in an older backup; the changed `storeEpoch` prevents an old version from being mistaken for the same acknowledged state.

Before opening a promoted writer, fence the old writer at the database/network/credential level, not merely through DNS; prove it cannot accept writes. Disable unresolved writers if authority is uncertain. Restore and verify the recovery point, replay the independent deletion journal, change `storeEpoch`, reconcile queue/outbox state and publish the routing epoch. Every rollback recovery or promotion invalidates all restored Local sessions using an externally recorded recovery authentication cutoff; session records are bound to `storeEpoch` and old-epoch sessions are never accepted. Fresh bootstrap requires provider authentication after the recovery cutoff, not merely a refreshed token, as well as account eligibility after deletion replay. This prevents an older backup from restoring a previously revoked session without requiring a separate per-session revocation journal. Test that case explicitly. Only then enable private mutations. If the old writer later returns, keep it isolated until reconciled and rebuilt as a non-writer.

Clients seeing a changed `storeEpoch` stop automatic replay, invalidate old cursors/ETags and perform a complete snapshot. Preserve local pending intents and reconcile them with explicit conflict handling; never reinterpret pre-restore operations as new writes silently. Report the known lost-commit window when asynchronous regional recovery has nonzero RPO. Notify affected users through an approved incident communication process; do not claim zero data loss because the service is responding again.

23.4 Public release and signing protocol

Dataset states are BUILDING, VALIDATING, READY, ACTIVE, RETIRED and FAILED. Only READY can become ACTIVE. Build, checksum and validate all graph/tile/pack components before switching an area pointer. Old releases remain readable for active request/cursor lifetimes. Graph deployment is blue/green: load the complete new mode graph, run smoke routes, shift traffic and drain old requests. No in-place mutation of a graph serving requests is permitted.

Use JWS compact serialization with ES256 for signed release manifests and active pointers, implemented by a maintained JOSE library. The protected header contains a fixed artifact type, `alg=ES256` and an allowlisted kid; reject none, unexpected algorithms, embedded keys, remote key URLs and unsupported critical headers. Verify the original signed payload bytes before parsing them. Strictly reject duplicate JSON keys. JWS and its algorithm identifiers are defined by RFC 7515 and RFC 7518; key lifecycle, expiry and release policy below are Local requirements. [S14-S15]

Release metadata includes audience=local-mobile, artifactType, areald, publicationVersion, schemaVersion, issuedAt, expiresAt, hashes and lengths, source/content versions and allowed immutable asset origins. A pointer references a versioned manifest by hash. Publish pointer metadata with a maximum seven-day validity and a five-minute CDN TTL; refresh still-current pointers before expiry without changing the immutable underlying dataset. A new signed pointer receives a higher publicationVersion even when its dataset stays the same. If a referenced manifest would expire, issue a new immutable manifest with fresh validity, a new hash/path and a higher pointer publication version; never mutate an old manifest or treat a fresh pointer as extending an expired manifest. Asset URLs and redirects must stay within the approved object/CDN allowlist.

Separate online release-signing keys from the root trust authority. Use distinct signing authority for public packs, regional configuration and application releases. A pack signer cannot authorize a regional host. Root-authorized key metadata specifies key purpose, validity, revocations and monotonic trust version; updating the root trust set requires an application release in the initial design. Protect root authorization offline or in a separately controlled HSM workflow requiring two authorized people. A release-key compromise cannot authorize a new root or another release key. Exercise normal rotation and compromise recovery on both mobile platforms before accepting the signing design.

After authenticating a key/record revocation, quarantine affected installed data and stop presenting it as verified. Select an independently trusted prior release or the independently reviewed app-bundled emergency fallback whose trust is not affected. If no such local fallback exists, show the failure explicitly and retain only clearly marked non-verified reference information permitted by the safety policy. Do not continue to execute/parse suspect pack content. An offline device cannot receive a new revocation; the product must not imply otherwise.

23.5 Deletion and restoration protection

Deletion creates a durable account tombstone and a deletion-journal entry outside the ordinary application backup rollback domain before the deletion request is acknowledged as durably accepted. The home transaction records the revocation/outbox atomically, and the API returns 202 only after the independent journal confirms durable receipt. A timeout leaves private access disabled; the receipt-recovery endpoint in Section 22.5 safely resolves that same recorded command despite the revoked Local session. The journal stores minimum identifiers and policy evidence, no coordinates or saved-place payloads. Replicate/protect it under approved regional/transfer rules and retain it longer than every backup, snapshot, replica and processor restore window it protects. A production restore fails closed if the journal cannot be verified and replayed.

The deletion workflow cancels exports, revokes sessions/provider grants, stops sync and provisioning events, purges private caches/materialized snapshots, deletes active and processor-held private records, and expires backup copies under the published policy. It also addresses the identity directory: keep only the minimum tombstoned binding necessary to block stale provisioning/recovery through its safety window, then remove it under the approved retention policy only after outstanding credentials/provisioning events and supported restore windows cannot revive the identity. Replay old bootstrap/resolve requests and restored directory records in the deletion acceptance tests. Directory control data is personal data, not exempt metadata. Preserve legally required records only with a recorded purpose, expiry and restricted access.

The restore test must include an account deleted after the selected backup point. It must stay inaccessible and absent from served private data after restoration. Old queue events, provider callbacks and registration retries must not recreate it. A deletion receipt remains truthful about incomplete processor work and backup expiry; operators cannot mark completion merely because the primary row was deleted.

24 Final release record and requirement traceability

24.1 Baseline decisions

The following engineering choices are fixed for implementation unless a reviewed architecture decision changes this document: React Native mobile; Spring modular monolith deployed as replicated stateless APIs; PostgreSQL/PostGIS; managed regional state; independent OSRM mode fleets; private account home-region writer; global public artifacts; managed OIDC code plus PKCE; encrypted private on-device storage; versioned signed offline packs; conditional/idempotent saves; at-least-once outbox processing; and capability-gated rollout across the first five countries.

The worldwide destination is fixed. Actual pilot cities, cloud account ownership, monthly spending approval, named operators, identity/weather/FX/tile suppliers, supported device/OS matrix and jurisdiction-specific legal findings are release inputs owned by the product and engineering organization. They cannot be fabricated by labelling a document final. Resolve them using the contract and acceptance criteria here; a supplier choice must not silently weaken those criteria.

Numerical API limits, timeouts, session lifetimes and retention rules are implementation defaults, with jurisdictional overrides as stated. Traffic forecasts and cost arithmetic are sizing assumptions. SLOs are release test targets. None is a recorded benchmark result. Changes must identify the affected tests, cost/privacy impact, approving owner and new effective document version.

24.2 Findings to verification mapping

Finding group	Required implementation evidence	Gates
F01 and F06	Hash-bound independent content approval, scoped staff roles, signed publication and withdrawal drill	G1, G6, G12
F02 and F03	Provider integration, session/recovery race tests, owner-scoped policies, directory and lifecycle tests	G1, G2, G5
F04	End-to-end telemetry inspection, rights workflows, country obligations and restore-safe erasure	G2, G10
F05 and F12	Signed packs, safe extraction, private-store isolation, offline feature matrix and interrupted-install tests	G2, G4
F07, F14, F17 and F18	Bounded workloads, spatial query plans, isolated builds, cache failure and realistic load report	G3, G7, G8
F08 and F09	Input/egress controls, private topology, transport encryption, workload IAM and secret rotation	G1, G3, G12
F10 and F19	Account-region uniqueness, fenced writer recovery, lineage reset, restored deletion replay	G5, G8, G9
F11 and F20	Per-mode local routes, city/category coverage and timezone/language device cases	G6, G11
F13 and F21	Artifact/provider licenses, required ODbL duties and approved five-country operating estimate	G10, G12

Finding group	Required implementation evidence	Gates
F15, F16 and F22	Concurrent/idempotent sync, signed delivery, independent security assessment and accountable runbooks	G1, G5, G12

24.3 Evidence and launch authorization

Create one release record containing release ID, commit/build digests, app/backend/schema/graph/pack versions, supported countries/cities/modes, supplier configurations, regions, declared load stage, gate results, recovery evidence, unresolved risks and expiry dates. Each result includes test date/environment, responsible person and a link to immutable evidence. A passing result from a different implementation or dataset is not transferable without documented impact review.

The engineering lead confirms functional and concurrent correctness; the security reviewer confirms security evidence and exceptions; the data/content owner confirms emergency and city certification; the platform owner confirms capacity, backup, monitoring and on-call readiness; the privacy owner confirms country applicability and processor/retention controls; the product owner approves scope and budget. Record each decision, identity and date. This specification supplies no invented approval signatures or passing test results.

A release is authorized only when required G1-G12 evidence is PASS for enabled features, all Critical findings are closed, affected High findings are closed or subject to an explicitly permitted time-limited exception, and the Section 18 non-waivable stop-ship conditions are absent. An exception requires an owner, compensating control, residual risk, expiry and a test proving that the disabled/exposed scope is understood. Product preference alone cannot waive cross-account access, unsafe emergency data, exposed credentials/precise location, corrupt pack activation, untested recovery or lost writes beyond the declared recovery contract.

Use the beta load stage first unless an approved forecast justifies another. Launch in invited cohorts, review reliability/content/cost evidence, and increase each country's certified coverage independently. Stop expansion on exhausted error budget, unsafe data, uncontained leakage or an exceeded approved capacity ceiling. Roll back affected features/datasets using the tested runbook while preserving local emergency access. This is the final engineering baseline for implementation; the release record is the separate evidence-based authorization to serve production users.